

	Universidad Autónoma Tomás Frías Carrera: <i>Ingeniería de Sistemas</i> Materia: <i>Seguridad de Sistemas sis-737</i>	PRACTICA_2
	Estudiante: Univ. Lisbeth Cuenca Mamani Docente: M. Sc. Ing. Javier Alexander Durán Miranda Auxiliar: Univ. Aldrin Roger Perez Miranda CI: 12846091 – RU: 108838	20 / 10 / 25

El Dpto de T.I. de una empresa financiera, tiene más de 15 años en el mercado y como parte de la información recopilada de un estudio, se identificaron los siguientes puntos:

1. Se desarrollo un nuevo sistema de gestión que será utilizado en la institución, el cual tiene todas las medidas de seguridad correctas en criptografía, controles de accesos, tiempo de sesiones, bitácoras o tablas de auditoría.
2. Se cuenta con un equipamiento de última generación a nivel de servidores, unidades de almacenamiento y equipos de redes que están operando por 1 año.
3. Debido al volumen de información generada diariamente y para extender el espacio de almacenamiento, se decide deshabilitar las tablas de auditoría del sistema.
4. Se realizan backups con un esquema de 10 copias, mismas que son almacenadas a más de 25 Km del CPD principal.
5. Como parte de un convenio interinstitucional, se reciben semestralmente 3 practicantes de Informática, los cuales pueden llevar sus laptops y acceder a la red a partir de ellas para realizar las actividades que les soliciten.
6. Existe un firewall de red, donde se habilita el puerto 22 para el acceso remoto, habilitado únicamente para el responsable de redes y jefe de T.I. de la institución en caso de necesitar acceder los servidores.
7. Recientemente finalizó la licencia de antivirus de pago que se contrataba anualmente, y considerando que es una inversión elevada, se opta por utilizar la versión gratuita, ya que no existen información importante almacenada en las computadoras que usan los funcionarios, toda información importante está en el servidor que usa una distribución Linux.
8. Debido a la necesidad de garantizar el 24/7, se cancela por el servicio en la nube para tener el equipamiento virtualizado mínimo en caso de que el CDP sufra algún desastre.

Identificar los elementos que deban ser analizados siguiendo la metodología de 6 pasos.

1. ALCANCE

el Departamento de Tecnologías de Información (T.I.) de la Institución financiera “Oportunidad” y los procesos que se desarrollan en esta unidad.

2. IDENTIFICAR ACTIVOS:

Software y aplicaciones: (Sistema de gestión, licencia de antivirus, firewall de red)

Dispositivos: (servidores, unidades de almacenamiento, equipos de redes, laptops personales de practicantes)

Personal: (Practicantes, responsable de redes, jefe de T.I.)

Telecomunicaciones: (acceso remoto)

Instalaciones: (Departamento de T.I.)

Valorar Activos

ACTIVO					IMPORTANCIA
SOFTWARE Y APLICACIONES	D	I	C	TOTAL	MUY ALTA MUY ALTA
• Sistema de gestión	5	5	4	$14/3=4,67 \rightarrow 5$	
• Antivirus	5	4	5	$14/3=4,67 \rightarrow 5$	
DISPOSITIVOS	D	I	C	TOTAL	ALTA ALTA BAJA MUY ALTA
• Equipos de redes	5	4	3	$12/3=4$	
• Unidad de almacenamiento	4	5	4	$13/3=4,33 \rightarrow 4$	
• Laptops personales	1	2	2	$5/3=1,67 \rightarrow 2$	
• Servidores	5	4	5	$14/3=4,67 \rightarrow 5$	
PERSONAL	D	I	C	TOTAL	BAJA ALTA ALTA
• Practicantes	2	2	1	$5/3=1,67 \rightarrow 2$	
• Responsable de redes	4	4	3	$11/3=3,67 \rightarrow 4$	
• Jefe de T.I.	4	4	3	$11/3=3,67 \rightarrow 4$	
TELECOMUNICACIONES	D	I	C	TOTAL	ALTA
• Acceso remoto	3	4	4	$11/3=3,66 \rightarrow 4$	
INSTALACIONES	D	I	C	TOTAL	MEDIA
• Edificio de Dto de T.I	4	4	1	$9/3=3$	

3. IDENTIFICAR LAS AMENAZAS:

ACTIVO: SOFTWARE Y APLICACIONES
- Debido al volumen de información generada diariamente y para extender el espacio de almacenamiento, se decide deshabilitar las tablas de auditoría del sistema (AMENAZA: ERRORES Y FALLOS NO INTENCIONADOS) -> Manipulación de los registros de actividad (I), al deshabilitar las tablas de auditoría que son necesarias para garantizar el no repudio, el sistema pierde la capacidad de verificar la veracidad e integridad de su información. - Recientemente finalizó la licencia de antivirus de pago que se contrataba anualmente, y considerando que es una inversión elevada, se opta por utilizar la versión gratuita, ya que no existen información importante almacenada en las computadoras que usan los funcionarios, toda información importante está en el servidor que usa una distribución Linux. (ATAQUES INTENCIONADOS) -> Difusión de software dañino (I, D, C), Destrucción de información (D), al usar un antivirus menos robusto, los equipos quedan más expuestos a software malicioso y otras amenazas que podrían propagarse por la red, y en el peor de los casos, afectar el servidor donde se almacena la información crítica.
ACTIVO: PERSONAL
Como parte de un convenio interinstitucional, se reciben semestralmente tres practicantes de Informática, los cuales pueden llevar sus laptops y acceder a la red a partir de ellas para realizar las actividades que les soliciten. (AMENAZA: ERRORES Y FALLOS NO INTENCIONADOS) -> Fugas de información (C), al dejar acceder desde laptops personales a la red, aumenta el riesgo de que información sensible se filtre o se copie de manera involuntaria, comprometiendo la confidencialidad de los datos.

4. IDENTIFICAR VULNERABILIDADES

ACTIVO: SOFTWARE Y APLICACIONES
Debido al volumen de información generada diariamente y para extender el espacio de almacenamiento, se decide deshabilitar las tablas de auditoría del sistema -> AUSENCIA DE PISTAS DE AUDITORÍA al dejar acceder desde laptops personales a la red, aumenta el riesgo de que información sensible se filtre o se copie de manera involuntaria, comprometiendo la confidencialidad de los datos.

- Recientemente finalizó la licencia de antivirus de pago que se contrataba anualmente, y considerando que es una inversión elevada, se opta por utilizar la versión gratuita, ya que no existen información importante almacenada en las computadoras que usan los funcionarios, toda información importante está en el servidor que usa una distribución Linux. -> **AUSENCIA DE CONTROL DE CAMBIOS, DEFECTOS BIEN CONOCIDOS DE SOFTWARE**, al usar un antivirus menos robusto, los equipos de los usuarios quedan más expuestos a malware y otras amenazas que podrían propagarse por la red y, en el peor de los casos, afectar el servidor donde se almacena la información crítica.

ACTIVO: PERSONAL

- Como parte de un convenio interinstitucional, se reciben semestralmente tres practicantes de Informática, los cuales pueden llevar sus laptops y acceder a la red a partir de ellas para realizar las actividades que les soliciten. -> **TRABAJO NO SUPERVISADO DE PERSONAL EXTERNO**. Los practicantes externos acceden a la red sin supervisión completa, lo que aumenta la posibilidad de fuga accidental de información o errores que afecten la red.

5. EVALUAR RIESGOS

ACTIVO: SOFTWARE Y APLICACIONES							
N°	DESCRIPCION DEL RIESGO	Probabilidad	IMPACTO				RIESGO
			FINANCIERO	IMAGEN	OPERATIVO	TOTAL	
1	Tablas de auditoría deshabilitadas riesgo de pérdida de integridad.	5	3	4	2	3	15
2	Antivirus menos robusto, propagación de malware maligno al servidor.	4	4	2	5	3,66 ->4	14,666
RIESGO PROMEDIO							14,833

ACTIVO: PERSONAL							
N°	DESCRIPCION DEL RIESGO	Probabilidad	IMPACTO				RIESGO
			FINANCIERO	IMAGEN	OPERATIVO	TOTAL	
1	Fuga de información por laptops personales conectadas a la red	5	3	3	4	3,33 ->3	16,665
RIESGO PROMEDIO							16,665

RESUMEN DE PROBABILIDAD / RIESGO

	DESCRIPCIÓN	PROBABILIDAD	IMPACTO	ACTIVO
1	Tablas de auditoría deshabilitadas riesgo de pérdida de integridad.	5	3	Software y Aplicaciones
2	Antivirus menos robusto, propagación de malware maligno al servidor.	4	3	Software y Aplicaciones
3	Fuga de información por laptops personales conectadas a la red	5	3	Personal

MATRIZ DE RIESGOS

IMPACTO	MUY ALTO (5)	MEDIO	MEDIO	ALTO	MUY ALTO	MUY ALTO
	ALTO (4)	BAJO	MEDIO	ALTO	ALTO	MUY ALTO
	MEDIO (3)	MUY BAJO	BAJO	MEDIO	ALTO	ALTO
	BAJO (2)	MUY BAJO	BAJO	BAJO	MEDIO	MEDIO
	MUY BAJO (1)	MUY BAJO	MUY BAJO	MUY BAJO	BAJO	MEDIO
		MUY BAJO (1)	BAJO (2)	MEDIO (3)	ALTO (4)	MUY ALTO (5)
		PROBABILIDAD				

6. TRATAR RIESGO

ACTIVO	Riesgo	Contramedidas
Software y Aplicaciones	Tablas de auditoría deshabilitadas riesgo de pérdida de integridad.	Habilitar los logs con rotación automática o ampliar el almacenamiento, para conservar el registro completo sin perder integridad.
Software y Aplicaciones	Antivirus menos robusto, propagación de malware maligno al servidor y demás equipos.	Mantenerlo siempre actualizado y segmentar la red para que, en caso de infección, el servidor no se vea afectado.
Personal	Fuga de información por laptops personales de practicantes, conectadas a la red	Limitar su acceso a una VLAN o VPN separada y supervisada, evitando que dispositivos externos comprometan la red interna.